

정보보호시스템 보안기능 점검표

대분류	보안기능 요구사항	점검결과	비고
감사기록	감사의 시작/종료, 관리자 또는 사용자에 대한 식별 및 인증성공/실패, 제품 설정 변경내역, 보안기능 수행 내역 등 감사데이터 생성 * 네트워크 차단 기능이 있는 경우 허용 및 차단된 모든 트래픽에 대한 감사 데이터 생성		
	감사 데이터는 사건 발생일시, 사건유형, 사건을 발생 시킨 주체의 신원(가능 경우), 작업내역 및 결과(성공/실패)를 상세히 포함		
	인가된 관리자가 제품구성요소로부터 생성된 모든 감사데이터를 검사할 수 있는 기능 제공		
	인가된 관리자 또는 인가된 사용자가 AND, OR 등 논리적 관계기준에 기초하여 감사레코드를 선택적으로 검토		
	감사 증적내 저장된 감사레코드에 대해 비인가된 삭제 또는 변경이 발생하지 않도록 보호 - 인가된 관리자라 할지라도 삭제 또는 변경할 수 없도록 삭제·변경 관련 유저인터페이스가 제공되지 않아야 됨 - 감사레코드에 대한 보호대책을 제품의 보안기능으로 완전히 구현할 수 없는 경우, 운용환경의 지원을 받을 수 있음		
	감사 증적의 크기가 지정된 한도를 초과할 경우, 사전 정의한 방식에 따라 관리자에게 통보		
	감사 증적의 포화시 적절한 방법(예:오래된 감사레코드 덮어쓰기 등)으로 저장 실패에 대응		
	주요 사건에 대한 정확한 시각 정보생성을 위해 신뢰된 OS등을 이용하여 시간 정보를 생성		
	잠재적인 보안위반을 탐지한 경우, 인가된 관리자가 설정한 대응(예:정보메세지 발송 등)을 수행		
식별 및 인증	관리자 또는 사용자 신원을 검증하기 위해 식별 및 인증기능 제공		
	관리자 인증실패가 설정된 횟수(기본값 5회이하)에 도달하면, 인가된 관리자가 설정한 시간(기본값 5분 이상)동안 식별 및 인증기능이 비활성화		

대분류	보안기능 요구사항	점검결과	비고
	패스워드 등록시 보안성기준(영문대문자/영문소문자/숫자/특수문자 중 3가지 이상의 규칙조합 및 9자리 이상으로 구성)을 만족하는지 검증		
	인증이 진행되는 동안 관리자 또는 사용자에게 패스워드가 마스킹(예:****등)되어 보이도록 해야 됨		
	식별 및 인증 실패시 실패이유에 대한 피드백(예:ID 오류, 패스워드 오류 등)을 제공하지 않아야 됨		
	관리자가 제품에 최초 접속시 제품이 기본적(예:설치시 등)으로 제공하는 ID 및 패스워드의 변경을 강제화하는 기능 제공		
	관리자의 패스워드가 제품에 하드코딩되거나 평문(단순인코딩 포함)으로 저장되지 않아야 함		
	인증정보가 재사용되는 것을 방지(타임스탬프 사용 등)해야 됨		
보안관리	인가된 관리자가 보안기능, 보안정책 및 중요데이터 등을 설정 및 고나리할 수 있는 보안기능 제공		
	사전 등록된 IP주소의 관리콘솔(관리자 IP주소 등록은 2개 이하로 제한)만 제품에 접속할 수 있도록 해야 함		
전 송 데 이 터 보 호	물리적으로 분리된 제품 구성요소간 전송데이터(보안정책, 제어명령, 감사기록 등)에 대한 암호화를 통해 기밀성 및 무결성 보장		
	- 에이전트와 관리서버간 전송되는 데이터에 대한 기밀성 및 무결성 보장을 위해 상호 인증을 수행 - 암호보둘 검증제도에서 검증대상으로 지정된 안전한 암호 알고리즘 사용을 권고 - 관제대상 시스템으로부터 로그를 Syslog형태로 수신하는 경우 본 요구사항은 적용되지 않음, 단 전송 과정에서 로그정보가 훼손될 수 있으므로 동일 로컬 네트워크 내에서만 Syslog사용 등 보호대책을 마련해야 됨		
	관리자의 웹브라우저를 이용한 접속 등 제품과 원격으로 연결된 모든 통신 수단은 안전한 암호통신 프로토콜을 사용		
자체시험	제품의 정확한 운영을 보장하기 위해 시동시와 정규 운영동안 주기적으로 자체 시험을 실행		
	인가된 관리자에게 제품의 설정값 및 제품 자체의 무결성을 검증하는 기능 제공		
안전한 세션 관리	로그인 이후 일정시간(기본값 10분이하)동안 동작이 없을 경우 세션 잠금 또는 세션 종료 기능을 수행		
	로그인 이후 다른 단말에서 동일 계정 또는 동일 권		

대분류	보안기능 요구사항	점검결과	비고
	한으로 로그인을 다시 수행하는 경우, 신규 접속을 차단하거나 이전 접속을 종료 *제품 운영상화 등에 대한 모니터링만 수행하는 관리자 계정에 대해서는 중복 로그인 허용 가능		
정 보 호 림 통제	인가된 관리자에 의해 설정된 규칙에 따라 인입 및 트래픽을 차단 - 정보흐름통제 규칙은 개별 또는 특정 대역의 출발지/목적지 주소 및 포트 등 다양한 정보에 의해 구성 - 3,000개 이상의 차단 규칙 생성·관리(ips에 한함) - 기본적으로 모든 트래픽을 차단한 뒤, 규칙에 따라 특정서비스/포트 출발지/목적지 주소기반은 화이트리스트 방식이, 시그니처 또는 유해사이트 목적기반은 블랙리스트 방식 적용을 권고하나 장애시 모든 트래픽을 통과시킬 수 있는 기능은 제공되지 않아야 함		
	제품 설정 등을 통해 다음의 정보흐름 차단 가능 - 외부로부터 들어오는 트래픽 중 내부 IP주소가 출발지인 트래픽 - 내부에서 나가는 트래픽 중 외부 IP주소가 출발지인 트래픽 - 외부로부터 들어오는 트래픽 중 브로드캐스트 주소가 목적지인 트래픽 - 외부로부터 들어오는 트래픽 중 루프백 주소가 목적지인 트래픽 - 외부로부터 들어오는 트래픽 중 비정상적인 패킷 형식을 가지는 트래픽		